

ETHICAL HACKING

Course Code: ITA1407

NAME: Purusothaman A

Reg No: 192421405

Port Scanning Challenge – Security Assessment

1. Identifying and Prioritizing Vulnerabilities

After discovering multiple open ports during a port scan, I would first identify the services and applications running on each port. Service and version information can help determine whether the service is outdated, misconfigured, or affected by known vulnerabilities.

I would then prioritize the findings based on:

- **Severity:** Critical and high-severity vulnerabilities should be addressed first.
- **Internet exposure:** Services accessible directly from the internet receive higher priority.
- **Service importance:** Database, remote-access, authentication, and file-transfer services can present significant risks.
- **Known vulnerabilities:** Identified software versions should be compared with trusted vulnerability databases such as the CVE database.
- **Authentication and encryption:** Services using weak authentication or unencrypted communication require additional attention.
- **Business impact:** Vulnerabilities affecting sensitive data or important systems should be handled urgently.

This approach ensures that the most dangerous and exploitable weaknesses are addressed before lower-risk issues.

2. Difference Between SYN Scan and TCP Connect Scan

A SYN scan and a TCP Connect scan can produce different results because they establish connections differently.

A SYN scan sends a SYN packet and analyzes the response without completing the full TCP connection. A TCP Connect scan completes the normal TCP three-way handshake with the target service.

- Firewalls or intrusion-prevention systems may treat the scans differently.
- Network filtering or packet loss can affect results.
- Rate limiting may influence responses.
- Different firewall rules may exist for incomplete and complete TCP connections.
- The service may change state during the scan.
- Operating-system or network-stack behavior can cause differences.
- Security software may detect and block one type of scan.

To verify the findings, I would repeat the scan under controlled conditions, compare results using different scan methods, check service/version information, and examine firewall or security-device logs when access is authorized. I would also confirm that the identified service is actually reachable and functioning as reported.

3. Most Ports Appear as “Filtered”

When most ports appear as filtered, it usually means that a security mechanism is preventing the scanner from determining whether the ports are open or closed.

- Firewalls blocking incoming packets.
- Intrusion Prevention Systems (IPS) detecting scanning activity.
- Access Control Lists (ACLs) restricting network traffic.
- Cloud security groups or network security rules.
- Rate limiting or automated blocking.
- Network segmentation preventing direct access to internal systems.

During an authorized assessment, I would gather additional information by examining permitted network paths, reviewing firewall and security logs, checking DNS and service information, and comparing results from approved scanning locations. If appropriate, I would also perform service enumeration against ports that are confirmed to be accessible.

The goal is not simply to bypass security controls, but to determine whether the filtering is intentional and whether any unnecessarily exposed services exist.

4. Comparison of TCP, UDP, and SYN Scanning

Technique	Description	Advantages	Limitations
TCP Connect	Completes the TCP handshake to determine whether a port is open.	Reliable when raw packet privileges are unavailable.	With the noticeable packet length, it may be detected in connection logs.
UDP	Sends UDP packets and analyzes responses to determine if a port is open.	Does not depend on DNS or other services.	Other UDP services and hardware may not respond because UDP often does not have a destination port.
SYN	Sends a TCP SYN and analyzes the response to determine if a port is open.	Fast and effective for identifying open ports.	May be detected by security systems and generally requires raw packet privileges.

A TCP Connect scan is useful when reliability is the priority or when raw packet privileges are unavailable. A UDP scan is important when assessing services that operate over UDP. A SYN scan is effective for quickly identifying TCP services during an authorized security assessment. No single technique is sufficient by itself; using appropriate techniques together provides a more complete view of the target’s network exposure.

5. Assessment of Internet-Exposed SSH, FTP, and Database Services

If an authorized security assessment identifies SSH, FTP, and database services exposed to the internet, I would treat them as important security findings and assess each service separately.

SSH

For SSH, I would check whether the software version is supported and fully patched, whether strong authentication is used, whether unnecessary accounts have SSH access, whether administrative access is appropriately restricted, and whether access can be limited to trusted networks.

Mitigation: Keep SSH updated, use strong authentication, disable unnecessary accounts and services, restrict administrative access, and apply firewall rules or VPN-based access where appropriate.

FTP

FTP can be risky because traditional FTP does not provide adequate protection for credentials and transferred data. I would check whether FTP is required, whether anonymous access is enabled, whether sensitive files can be accessed, whether a secure alternative such as SFTP or FTPS can be used, and whether the service is patched.

Mitigation: Disable FTP if it is unnecessary. Where file transfer is required, use a secure protocol such as SFTP, disable anonymous access, restrict permissions, and monitor file-transfer activity.

Database Services

Internet-facing database ports can create significant risk because attackers may attempt unauthorized access or exploit vulnerabilities in database software. I would assess the database version, authentication configuration, user privileges, unnecessary accounts, network accessibility, sensitive information, and firewall controls.

Mitigation: Databases should normally not be directly exposed to the public internet. Access should be restricted using firewalls, private networks, VPNs, or application-layer controls. Strong authentication, least-privilege permissions, encryption, regular patching, logging, and monitoring should also be implemented.

Conclusion

Port scanning is an important first step in an authorized security assessment because it reveals the network services that may be accessible to users or attackers. However, an open port does not automatically mean that a vulnerability exists. Each discovered service must be identified, analyzed, and evaluated according to its configuration, software version, exposure, and business impact.

The most critical risks should be prioritized first, particularly internet-facing services involving remote access, file transfer, authentication, or sensitive databases. Proper patching, firewall configuration, access control, strong authentication, encryption, network segmentation, and continuous monitoring can significantly reduce the risks identified during the assessment.